



OWASP PTK Security Report

Website Vulnerability Scanner Report

exam-red.edu-jalm.fr

Summary

Risk ratings:

Critical: 0
High: 7
Medium: 1
Low: 7
Info: 0

Engine	Critical	High	Medium	Low	Info	Total
DAST	0	0	1	7	0	8
IAST	0	7	0	0	0	7
Total	0	7	1	7	0	15

Confirmed high-risk issues detected; prioritize remediation.

Exposure & Hygiene:

Headers: Missing Content-Security-Policy header; Missing Strict-Transport-Security header (on HTTPS); Missing or invalid X-Content-Type-Options

Token/storage: Tokens in storage: No; Cookie HttpOnly missing: Yes

Dependencies: No high-risk dependencies identified or data unavailable.

Remediation Plan:

Bucket	Items
Fix now (0–7 days)	7
Fix soon (7–30 days)	1
Backlog	7

General Information

Technology Stack

Name	Version	Category
OpenResty		Web servers
Python		Programming languages
Django		Web frameworks
FortiWeb (Fortinet)		WAF

OWASP Secure Headers

Header
Missing Content-Security-Policy header
Missing Strict-Transport-Security header (on HTTPS)
Missing or invalid X-Content-Type-Options
COOP set without COEP/CORP (incomplete cross-origin isolation)
Missing or weak Referrer-Policy

Cookies

Domain	Name	Value	HttpOnly
.google.com	__Secure-BEET	CNwG	true
.google.com	__Secure-E-NID	33.SE=AfFbCBBMcDHL20k4hAhSfOVTikHC4BbnA3ufJiw8a2bCFrD1Ui-3Gf4KS7aSgWTzKlx3ShyWo5BCom4w7a59tLM7xA0oHsaQa0SdRMUX7-1TGm9FV_PT41m2LC5_GMB9JRe-DCCfMWiHdTVBhqsUQS1Gv2ahCQ8hAGv3MJc9WHJG_kZbpL1u_SqSisiCyoDI8Cm8HqvHB7thxymU_SQ3F1jol_z2IC2UExUwt6RyNKATC9bKWIYgEXuzEC3dIDXgJgImVbalZHmrw30w-LcgYZe5NZz1nOMCuqTsRJ15-06_D21bYhip	true
.google.com	AEC	AaJma5uEp2ivbiNadvPXkqNVKIPbX8Zq4Z05-mnS_lyWHipO2eDS1Y6Ft7Q	true
exam-red.edu-jalm.fr	csrftoken	J1ioxE2SLZME9QhMg8mzfBrdolPwnK1	false
exam-red.edu-jalm.fr	sessionid	avetxb0q3yrt612penabqze2r94ck9wb	true
.google.com	SOC	CAESHAgCEhJnd3NfMjAyNjA1MDYtMF9SQzEaAmZylAEaBgiA8vnPBg	false

Storage

Storage	Entries
localStorage	0
sessionStorage	0

DAST

DAST-0001 - Python traceback

https://exam-red.edu-jalm.fr/books/4/delete/

MEDIUM Confidence: 78

Request:

GET https://exam-red.edu-jalm.fr/books/4/delete/ HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: macOS
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://exam-red.edu-jalm.fr/books/4/
Accept-Encoding: gzip, deflate, br, zstd

Request:

Accept-Language: fr-FR,fr;q=0.9,en-US;q=0.8,en;q=0.7
Cookie: csrftoken: J1ioxE2SL...IPwnK1; session1...

Response:

HTTP/1.1 500 Internal Server Error
connection: keep-alive
content-length: 168227
content-type: text/html; charset=utf-8
cross-origin-opener-policy: same-origin
date: Thu, 28 May 2026 13:43:16 GMT
referrer-policy: same-origin
server: openresty
vary: Cookie
x-content-type-options: nosniff
x-frame-options: DENY

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta http-equiv="content-type" content="text/html; charset=utf-8">
  <meta name="robots" content="NONE,NOARCHIVE">
  <title>IntegrityError
    at /books/4/delete/</title>
  <style type="text/css">
    html * { padding:0; margin:0; }
    body * { padding:10px 20px; }
    body * * { padding:0; }
    body { font:small sans-serif; background-color:#fff; color:#000; }
    body>div { border-bottom:1px solid #ddd; }
    h1 { font-weight:nor...
```

Proof:

Traceback (most recent call last):

Description:

Detects common framework stack traces, error pages, and path disclosures in observed responses.

Recommendation:

Return generic error messages to clients and log detailed errors server-side.Disable debug/error pages in production and scrub internal paths/hostnames from responses.

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
<https://cwe.mitre.org/data/definitions/209.html>

DAST-0002 - Missing Content-Security-Policy header

<https://exam-red.edu-jalm.fr/accounts/>

LOW

Confidence: 78

Request:

POST https://exam-red.edu-jalm.fr/accounts/ HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: macOS
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Origin: https://exam-red.edu-jalm.fr
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://exam-red.edu-jalm.fr/accounts/
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: fr-FR,fr;q=0.9...

Response:

```
HTTP/1.1 403 Forbidden
connection: keep-alive
content-encoding: gzip
content-type: text/html; charset=utf-8
cross-origin-opener-policy: same-origin
date: Thu, 28 May 2026 13:32:48 GMT
referrer-policy: same-origin
server: openresty
transfer-encoding: chunked
x-content-type-options: nosniff
x-frame-options: DENY
```

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta http-equiv="content-type" content="text/html; charset=utf-8">
  <meta name="robots" content="NONE,NOARCHIVE">
  <title>403 Forbidden</title>
  <style type="text/css">
    html * { padding:0; margin:0; }
    body * { padding:10px 20px; }
    body * * { padding:0; }
    body { font:small sans-serif; background:#eee; color:#000; }
    body>div { border-bottom:1px solid #ddd; }
    h1 { font-weight:normal; margin-bottom:.4em; }
    h1 s...
```

Description:

The OWASP Secure Headers Project describes HTTP response headers that your application can use to increase the security of your application. Once set, these HTTP response headers can restrict modern browsers from running into easily preventable vulnerabilities.

Recommendation:

Configure security-related HTTP response headers consistently on all responses to harden the application against common browser-based attacks.

HSTS – enforce HTTPS with a long max-age and includeSubDomains where appropriate. Content-Security-Policy – restrict scripts, styles, frames and connections to trusted sources only. Referrer-Policy – limit referrer information sent to other origins. X-Content-Type-Options – use nosniff to prevent MIME type confusion. Cookies – set Secure, HttpOnly and SameSite attributes on sensitive cookies. Remove unnecessary disclosure headers such as Server and X-Powered-By where possible.

CWE:

CWE-693

OWASP:

A02:2025 - Security Misconfiguration, A05:2021 - Security Misconfiguration

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/

<https://cwe.mitre.org/data/definitions/693.html>

DAST-0003 - Environment hints (dev/staging/test) in response

<https://exam-red.edu-jalm.fr/accounts/>

LOW

Confidence: 78

Request:

```
POST https://exam-red.edu-jalm.fr/accounts/ HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: macOS
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Origin: https://exam-red.edu-jalm.fr
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
```

Request:

Sec-Fetch-Dest: document
Referer: https://exam-red.edu-jalm.fr/accounts/
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: fr-FR,fr;q=0.9...

Response:

HTTP/1.1 403 Forbidden
connection: keep-alive
content-encoding: gzip
content-type: text/html; charset=utf-8
cross-origin-opener-policy: same-origin
date: Thu, 28 May 2026 13:32:48 GMT
referrer-policy: same-origin
server: openresty
transfer-encoding: chunked
x-content-type-options: nosniff
x-frame-options: DENY

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta http-equiv="content-type" content="text/html; charset=utf-8">
  <meta name="robots" content="NONE,NOARCHIVE">
  <title>403 Forbidden</title>
  <style type="text/css">
    html * { padding:0; margin:0; }
    body * { padding:10px 20px; }
    body * * { padding:0; }
    body { font:small sans-serif; background:#eee; color:#000; }
    body>div { border-bottom:1px solid #ddd; }
    h1 { font-weight:normal; margin-bottom:.4em; }
    h1 s...
```

Proof:

dev

Description:

Detects internal hostnames/IPs and environment hints (staging/dev/local) disclosed in observed responses.

Recommendation:

Remove internal hostnames/IPs from client responses.Ensure staging/dev configuration is not exposed to production clients.

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
<https://cwe.mitre.org/data/definitions/200.html>

DAST-0004 - Environment hints (dev/staging/test) in response

<https://exam-red.edu-jalm.fr/books/1/edit/>

LOW

Confidence: 78

Request:

POST https://exam-red.edu-jalm.fr/books/1/edit/ HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: macOS
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Origin: https://exam-red.edu-jalm.fr
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://exam-red.edu-jalm.fr/books/1/edit/
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: fr-FR,...

Response:

```
HTTP/1.1 403 Forbidden
connection: keep-alive
content-encoding: gzip
content-type: text/html; charset=utf-8
cross-origin-opener-policy: same-origin
date: Thu, 28 May 2026 13:37:06 GMT
referrer-policy: same-origin
server: openresty
transfer-encoding: chunked
x-content-type-options: nosniff
x-frame-options: DENY
```

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta http-equiv="content-type" content="text/html; charset=utf-8">
  <meta name="robots" content="NONE,NOARCHIVE">
  <title>403 Forbidden</title>
  <style type="text/css">
    html * { padding:0; margin:0; }
    body * { padding:10px 20px; }
    body * * { padding:0; }
    body { font:small sans-serif; background:#eee; color:#000; }
    body>div { border-bottom:1px solid #ddd; }
    h1 { font-weight:normal; margin-bottom:.4em; }
    h1 s...
```

Proof:

dev

Description:

Detects internal hostnames/IPs and environment hints (staging/dev/local) disclosed in observed responses.

Recommendation:

Remove internal hostnames/IPs from client responses.Ensure staging/dev configuration is not exposed to production clients.

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
<https://cwe.mitre.org/data/definitions/200.html>

DAST-0005 - Environment hints (dev/staging/test) in response

<https://exam-red.edu-jalm.fr/books/4/edit/>

LOW

Confidence: 78

Request:

```
POST https://exam-red.edu-jalm.fr/books/4/edit/ HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: macOS
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Origin: https://exam-red.edu-jalm.fr
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://exam-red.edu-jalm.fr/books/4/edit/
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: fr-FR,...
```

Response:

```
HTTP/1.1 403 Forbidden
connection: keep-alive
content-encoding: gzip
content-type: text/html; charset=utf-8
```

Response:

```
cross-origin-opener-policy: same-origin
date: Thu, 28 May 2026 13:43:13 GMT
referrer-policy: same-origin
server: openresty
transfer-encoding: chunked
x-content-type-options: nosniff
x-frame-options: DENY
```

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta http-equiv="content-type" content="text/html; charset=utf-8">
  <meta name="robots" content="NONE,NOARCHIVE">
  <title>403 Forbidden</title>
  <style type="text/css">
    html * { padding:0; margin:0; }
    body * { padding:10px 20px; }
    body * * { padding:0; }
    body { font:small sans-serif; background:#eee; color:#000; }
    body>div { border-bottom:1px solid #ddd; }
    h1 { font-weight:normal; margin-bottom:.4em; }
    h1 s...
```

Proof:

dev

Description:

Detects internal hostnames/IPs and environment hints (staging/dev/local) disclosed in observed responses.

Recommendation:

Remove internal hostnames/IPs from client responses.Ensure staging/dev configuration is not exposed to production clients.

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
<https://cwe.mitre.org/data/definitions/200.html>

DAST-0006 - Internal IP address leaked in response

<https://exam-red.edu-jalm.fr/books/4/delete/>

LOW

Confidence: 78

Request:

```
GET https://exam-red.edu-jalm.fr/books/4/delete/ HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: macOS
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://exam-red.edu-jalm.fr/books/4/
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: fr-FR,fr;q=0.9,en-US;q=0.8,en;q=0.7
Cookie: csrftoken: J1ioxE2SL...IPwnK1; sessioni...
```

Response:

```
HTTP/1.1 500 Internal Server Error
connection: keep-alive
content-length: 168227
content-type: text/html; charset=utf-8
cross-origin-opener-policy: same-origin
date: Thu, 28 May 2026 13:43:16 GMT
referrer-policy: same-origin
server: openresty
vary: Cookie
```

Response:

x-content-type-options: nosniff
x-frame-options: DENY

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta http-equiv="content-type" content="text/html; charset=utf-8">
  <meta name="robots" content="NONE,NOARCHIVE">
  <title>IntegrityError
    at /books/4/delete/</title>
  <style type="text/css">
    html * { padding:0; margin:0; }
    body * { padding:10px 20px; }
    body * * { padding:0; }
    body { font:small sans-serif; background-color:#fff; color:#000; }
    body>div { border-bottom:1px solid #ddd; }
    h1 { font-weight:nor...
```

Proof:

10.250.0.5

Description:

Detects internal hostnames/IPs and environment hints (staging/dev/local) disclosed in observed responses.

Recommendation:

Remove internal hostnames/IPs from client responses.Ensure staging/dev configuration is not exposed to production clients.

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
<https://cwe.mitre.org/data/definitions/200.html>

DAST-0007 - localhost/127.0.0.1 referenced in response

<https://exam-red.edu-jalm.fr/books/4/delete/>

LOW

Confidence: 78

Request:

```
GET https://exam-red.edu-jalm.fr/books/4/delete/ HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: macOS
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://exam-red.edu-jalm.fr/books/4/
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: fr-FR,fr;q=0.9,en-US;q=0.8,en;q=0.7
Cookie: csrftoken: J1ioxE2SL...IPwnK1; sessioni...
```

Response:

```
HTTP/1.1 500 Internal Server Error
connection: keep-alive
content-length: 168227
content-type: text/html; charset=utf-8
cross-origin-opener-policy: same-origin
date: Thu, 28 May 2026 13:43:16 GMT
referrer-policy: same-origin
server: openresty
vary: Cookie
x-content-type-options: nosniff
x-frame-options: DENY
```

```
<!DOCTYPE html>
<html lang="en">
```


Response:

```
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<meta name="robots" content="NONE,NOARCHIVE">
<title>IntegrityError
      at /books/4/delete/</title>
<style type="text/css">
  html * { padding:0; margin:0; }
  body * { padding:10px 20px; }
  body * * { padding:0; }
  body { font:small sans-serif; background-color:#fff; color:#000; }
  body>div { border-bottom:1px solid #ddd; }
  h1 { font-weight:nor...
```

Proof:

localhost

Description:

Detects internal hostnames/IPs and environment hints (staging/dev/local) disclosed in observed responses.

Recommendation:

Remove internal hostnames/IPs from client responses.Ensure staging/dev configuration is not exposed to production clients.

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
<https://cwe.mitre.org/data/definitions/200.html>

DAST-0008 - Environment hints (dev/staging/test) in response

<https://exam-red.edu-jalm.fr/books/4/delete/>

LOW

Confidence: 78

Request:

```
GET https://exam-red.edu-jalm.fr/books/4/delete/ HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: macOS
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://exam-red.edu-jalm.fr/books/4/
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: fr-FR,fr;q=0.9,en-US;q=0.8,en;q=0.7
Cookie: csrftoken: J1ioxhE2SL...IPwnK1; sessioni...
```

Response:

```
HTTP/1.1 500 Internal Server Error
connection: keep-alive
content-length: 168227
content-type: text/html; charset=utf-8
cross-origin-opener-policy: same-origin
date: Thu, 28 May 2026 13:43:16 GMT
referrer-policy: same-origin
server: openresty
vary: Cookie
x-content-type-options: nosniff
x-frame-options: DENY

<!DOCTYPE html>
<html lang="en">
<head>
  <meta http-equiv="content-type" content="text/html; charset=utf-8">
  <meta name="robots" content="NONE,NOARCHIVE">
  <title>IntegrityError
        at /books/4/delete/</title>
```

Response:

```
<style type="text/css">
  html * { padding:0; margin:0; }
  body * { padding:10px 20px; }
  body * * { padding:0; }
  body { font:small sans-serif; background-color:#fff; color:#000; }
  body>div { border-bottom:1px solid #ddd; }
  h1 { font-weight:nor...
```

Proof:

testing

Description:

Detects internal hostnames/IPs and environment hints (staging/dev/local) disclosed in observed responses.

Recommendation:

Remove internal hostnames/IPs from client responses.Ensure staging/dev configuration is not exposed to production clients.

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
<https://cwe.mitre.org/data/definitions/200.html>

IAST

IAST-0001 - DOM XSS via DOM mutations

<https://exam-red.edu-jalm.fr/books/1/edit/>

HIGH

Confidence: 61

Meta:

- Source: location.pathname segment "books"
- Sink: dom.mutation
- Category: xss
- URL: <https://exam-red.edu-jalm.fr/books/1/edit/>

Context / Value:

<https://exam-red.edu-jalm.fr/books/1/edit/>

Trace:

Error: Sink: xss-bootstrap-sweep

Proof:

books

Description:

Tainted data inserted into the DOM via DOM mutation APIs.

Recommendation:

Avoid inserting untrusted strings into HTML or inline handlers.Prefer textContent or safe templating; sanitize with DOMPurify when HTML is required.Use CSP without unsafe-inline where possible.

CWE:

CWE-79

OWASP:

A05:2025 - Injection, A03:2021 - Injection

References:

<https://owasp.org/www-community/attacks/xss/>
<https://cwe.mitre.org/data/definitions/79.html>

IAST-0002 - DOM XSS via DOM mutations

<https://exam-red.edu-jalm.fr/books/1/>

HIGH

Confidence: 61

Meta:

- Source: location.pathname segment "books"
- Sink: dom.mutation
- Category: xss
- URL: <https://exam-red.edu-jalm.fr/books/1/>

Context / Value:

<https://exam-red.edu-jalm.fr/books/1/>

Trace:

Error: Sink: xss-bootstrap-sweep

Proof:

books

Description:

Tainted data inserted into the DOM via DOM mutation APIs.

Recommendation:

Avoid inserting untrusted strings into HTML or inline handlers. Prefer `textContent` or safe templating; sanitize with `DOMPurify` when HTML is required. Use CSP without `unsafe-inline` where possible.

CWE:

CWE-79

OWASP:

A05:2025 - Injection, A03:2021 - Injection

References:

<https://owasp.org/www-community/attacks/xss/>
<https://cwe.mitre.org/data/definitions/79.html>

IAST-0003 - DOM XSS via DOM mutations

<https://exam-red.edu-jalm.fr/loan/>

HIGH

Confidence: 61

Meta:

- Source: client route `"/loan/"`
- Sink: dom.mutation
- Category: xss
- URL: <https://exam-red.edu-jalm.fr/loan/>

Context / Value:

<https://exam-red.edu-jalm.fr/loan/>

Trace:

Error: Sink: xss-bootstrap-sweep

Proof:

`/loan/`

Description:

Tainted data inserted into the DOM via DOM mutation APIs.

Recommendation:

Avoid inserting untrusted strings into HTML or inline handlers. Prefer `textContent` or safe templating; sanitize with `DOMPurify` when HTML is required. Use CSP without `unsafe-inline` where possible.

CWE:

CWE-79

OWASP:

A05:2025 - Injection, A03:2021 - Injection

References:

<https://owasp.org/www-community/attacks/xss/>
<https://cwe.mitre.org/data/definitions/79.html>

IAST-0004 - DOM XSS via DOM mutations

<https://exam-red.edu-jalm.fr/books/4/>

HIGH

Confidence: 61

Meta:

- Source: location.pathname segment "books"
- Sink: dom.mutation
- Category: xss
- URL: <https://exam-red.edu-jalm.fr/books/4/>

Context / Value:

<https://exam-red.edu-jalm.fr/books/4/>

Trace:

Error: Sink: xss-bootstrap-sweep

Proof:

books

Description:

Tainted data inserted into the DOM via DOM mutation APIs.

Recommendation:

Avoid inserting untrusted strings into HTML or inline handlers. Prefer textContent or safe templating; sanitize with DOMPurify when HTML is required. Use CSP without unsafe-inline where possible.

CWE:

CWE-79

OWASP:

A05:2025 - Injection, A03:2021 - Injection

References:

<https://owasp.org/www-community/attacks/xss/>
<https://cwe.mitre.org/data/definitions/79.html>

IAST-0005 - DOM XSS via DOM mutations

<https://exam-red.edu-jalm.fr/books/4/edit/>

HIGH

Confidence: 61

Meta:

- Source: location.pathname segment "books"
- Sink: dom.mutation
- Category: xss
- URL: <https://exam-red.edu-jalm.fr/books/4/edit/>

Context / Value:

<https://exam-red.edu-jalm.fr/books/4/edit/>

Trace:

Error: Sink: xss-bootstrap-sweep

Proof:

books

Description:

Tainted data inserted into the DOM via DOM mutation APIs.

Recommendation:

Avoid inserting untrusted strings into HTML or inline handlers. Prefer textContent or safe templating; sanitize with DOMPurify when HTML is required. Use CSP without unsafe-inline where possible.

CWE:

CWE-79

OWASP:

A05:2025 - Injection, A03:2021 - Injection

References:

<https://owasp.org/www-community/attacks/xss/>

<https://cwe.mitre.org/data/definitions/79.html>

IAST-0006 - DOM XSS via DOM mutations

<https://exam-red.edu-jalm.fr/accounts/profile>

HIGH

Confidence: 61

Meta:

- Source: location.pathname segment "accounts"
- Sink: dom.mutation
- Category: xss
- URL: <https://exam-red.edu-jalm.fr/accounts/profile>

Context / Value:

<https://exam-red.edu-jalm.fr/accounts/profile>

Trace:

Error: Sink: xss-bootstrap-sweep

Proof:

accounts

Description:

Tainted data inserted into the DOM via DOM mutation APIs.

Recommendation:

Avoid inserting untrusted strings into HTML or inline handlers. Prefer textContent or safe templating; sanitize with DOMPurify when HTML is required. Use CSP without unsafe-inline where possible.

CWE:

CWE-79

OWASP:

A05:2025 - Injection, A03:2021 - Injection

References:

<https://owasp.org/www-community/attacks/xss/>

<https://cwe.mitre.org/data/definitions/79.html>

IAST-0007 - DOM XSS via DOM mutations

https://exam-red.edu-jalm.fr/accounts/edit_profile

HIGH

Confidence: 61

Meta:

- Source: location.pathname segment "accounts"
- Sink: dom.mutation
- Category: xss
- URL: https://exam-red.edu-jalm.fr/accounts/edit_profile

Context / Value:

https://exam-red.edu-jalm.fr/accounts/edit_profile

Trace:

Error: Sink: xss-bootstrap-sweep

Proof:

accounts

Description:

Tainted data inserted into the DOM via DOM mutation APIs.

Recommendation:

Avoid inserting untrusted strings into HTML or inline handlers. Prefer `textContent` or safe templating; sanitize with `DOMPurify` when HTML is required. Use CSP without `unsafe-inline` where possible.

CWE:

CWE-79

OWASP:

A05:2025 - Injection, A03:2021 - Injection

References:

<https://owasp.org/www-community/attacks/xss/>

<https://cwe.mitre.org/data/definitions/79.html>

Report generated using OWASP PTK scanning engines. Results depend on scan coverage and target responsiveness.

Scope: N/A

Limitations: Results depend on available routes and auth context; some flows may not be covered.